

Governing Enterprise AI: A Three-Layer Defense-in-Depth Model

Yuto Sugihara
Security Engineer at F-TECH INC.

Abstract—The increasing usage of artificial intelligence (AI) in the workplace has surpassed the security protocols that regulate AI. Employees may now utilize AI to develop and execute code, access sensitive data, and investigate internal systems, often using unauthorized "shadow AI" tools that operate outside of the company's control. The behavior described a governance quandary for information technology (IT) and security teams entrusted with protecting business assets: forbidding AI completely negates productivity benefits, leaving AI ungoverned, which exposes the firm to data leakage, toxic material, and exploitation. The article contends that no single control is sufficient and suggests a three-layer, defense-in-depth method for managing corporate AI deployment. The first layer develops organizational policy based on known frameworks like the NIST AI Risk Management Framework and the Economic Co-operation and Development (OECD) guidelines. The second layer employs Microsoft Entra ID to restrict which human and agentic identities can access an AI service. The third layer uses Amazon Bedrock Guardrails and Flows to filter out possibly dangerous inputs and replies. Together, the three levels convert a stated policy into enforceable technological limits, allowing a security team to properly manage AI use without imposing an explicit prohibition.

1 INTRODUCTION

Artificial Intelligence (AI) is becoming increasingly widespread in the workplace. People are adopting AI-powered chatbots to access information that was previously accessed through search engines. AI is also useful for coding, developing technological platforms, and detecting security concerns. The result is that anyone, regardless of an engineering or computer science background, may now code. According to Osmani, inexperienced engineers can rapidly create a functioning solution using AI but will soon become stuck when reaching the more difficult elements of the process [1].

Access to AI services is straightforward, and acceptance expands more quickly than businesses can counteract. Having a rapid speed raises several concerns. When AI is used to execute instructions on company computers, security systems such as endpoint detection and response (EDR) software may flag the behavior as suspicious, causing warnings to be raised and consuming the time of the personnel expected to handle the alerts. Another issue is that people with limited technical skills may utilize AI to hack into systems.

The core difficulty is how a team of Information Technology (IT) and security professionals can monitor AI use throughout an organization without completely removing AI. A single control is insufficient; good governance needs several levels of security. The present research presents a three-layer control paradigm for corporate AI. The first layer is a company AI policy that defines what is and isn't allowed. The second layer uses identity-based authentication, such as Microsoft Entra ID, to determine which users can access which AI services. The third layer uses cloud-based protection, such as Amazon Web Services (AWS), to prevent dangerous or malicious inputs. The next sections explain how each layer works, compare identity-based control to network-level blocking, and look at prompt-level defenses for both benign and malicious inputs.

2 ORGANIZATIONAL AI POLICY

Creating instructions on how to utilize AI is tough since organizations should not simply declare and proclaim that all workers are not permitted to use unapproved AI tools, nor should employees be forced to use technologies that have already been developed and built by an internal systems department. AI at work is akin to powerful tools on personal devices, and developing an AI policy impacts a company's productivity and revenue. According to Malter, an organizational AI policy is a framework that establishes basic guidelines for deploying AI safely and responsibly. Employees utilize AI to complete assigned tasks. An AI policy helps to prevent problems, such as people gaining access to material that should be limited and copying work that belongs to someone else. Companies need an AI policy for the responsible use of AI. The AI policy ensures that employees use AI safely and in compliance [2]. On the other side, a policy is required so that staff may utilize AI comfortably while doing given jobs. Each company's prospective AI policies should contain public recommendations for developing global corporate AI policies, cultural and country-specific issues, risk management, and AI implementations.

2.1 General Policies from Third-Party Organizations

Developing policies is complicated and time-consuming. Moving from old to new policies requires an adjustment period. Many firms have struggled to develop or modify internal policies. Public norms and policies already exist throughout the world. For example, the National Institute of Standards and Technology (NIST) and the Organization for Economic Co-operation and Development (OECD) have issued comprehensive, widely referenced guidance.

NIST has released the AI Risk Management Framework,

which provides a strategy that people can agree on to make AI systems trustworthy. The framework assists in considering the hazards of employing AI. The strategy is divided into four parts: governing AI, mapping out what a system performs, measuring how well a system works, and managing any problems that arise [3]. The four components can be used in many ways, depending on what AI is required for and how much risk a business is prepared to accept. Some guidelines explain how to do so in certain scenarios. AI systems must be trustworthy; hence, the strategy aims to ensure that AI systems are safe to use. Furthermore, NIST highlights AI Risk Management and Human-AI Interaction, which exemplifies how knowing the constraints of how people interact with AI systems is necessary for AI risk management [4]. Human oversight of AI requires defining roles. Humans and systems can both have biases, which must be considered. People will perceive the information that AI systems report in various ways. The Govern and Map roles of AI risk management aid interpretation by ensuring that everyone's role is understood, making choices explicit, assisting individuals in learning what is required, utilizing diverse teams, and conducting ongoing research.

The OECD has a comparable standing to the NIST framework, although the OECD is more human-oriented. The organization's ideals are significant because the principles contribute to the creation of new and interesting AI that is trustworthy and fair to people. In a democratic society, AI must consider human rights and preferences. The OECD values are designed to be helpful and adaptable throughout time [5]. The principles are based on five ideas: ensuring that everyone benefits and is happy; treating people fairly and respecting human rights and democratic values, including being fair and protecting people's private information; being open and honest about how AI works; ensuring that AI is strong, safe, and secure; and accepting responsibility for what AI does. AI must adhere to the principles in order to be trustworthy and respectful of rights and democratic ideals.

AI policies should be incorporated in the purview of risk management, preferably as a top priority, because IT security experts cannot handle all vulnerabilities or events created by workers using AI without addressing risk management. As a result, recognizing hazards is important; the risks often fall into uncertain or hard-to-quantify categories. Any risk that humans might envision can occur. As a result, a strategy should be developed to govern settings capable of risk management and to establish norms under which employees may safely utilize AI. Regarding cybersecurity, a policy should close any security gaps that may arise as a result of AI, including human mistakes.

2.2 Cultural/Countries Concerns

Culture, law, and regulation vary from one jurisdiction to

another in which a multinational corporation operates, and an organization with overseas offices must stay current on local laws and customs. National culture also influences the response of employees to rules in the workplace. Cross-cultural work values research differentiates between individualist societies, where people are comfortable taking personal responsibility, and collectivist societies, where consensus and group expectations influence decision-making [6]. Traditionally, the United States and Japan have exemplified the contrast. In Hofstede's original data, the United States scored much higher on individualism than did Japan, and the expectations in the United States at work emphasize individual initiative, whereas Japanese organizations have tended to favor collective, consensus-based decision making [7]. When a single company-wide AI strategy is adopted across varied national settings, what appears to be natural in one country may conflict with local conventions in another. In an individualist country like the United States, employees may feel comfortable employing AI technology freely and accepting personal responsibility for the results. A policy that supports individual responsibility in the absence of a clear group procedure may be poorly received or ignored in a collectivist country such as Japan, where the same personnel may expect decisions to be made by consensus and to be consistent with collective expectations before acting. Culture is not the only factor that influences the legal environment. Data protection legislation, such as the European Union's General Data Protection Regulation (GDPR), sets tight limits on the handling of personal data [8]. The GDPR legislation has a direct influence on what employees can provide for an AI service and where that data can be maintained. As a result, a policy authorizing specific AI inputs at a company's headquarters may be prohibited abroad.

2.3 Implementation

The execution of AI policy is critical to how the policy mirrors the whole organizational structure. The effect would change depending on which department is in charge of executing the newly constituted policy. Simply developing and executing policies will not result in conflict-free outcomes. The most important objective is to build settings and policies that allow the organization to be controlled by adhering to the policies. For example, a corporation may choose to utilize a single AI provider and specify the provider as a policy. Before publicizing the policy, the organization must establish an environment in which employees may only utilize one specific AI service. In the case, the simplest way to block all AI services except for one is to register a block list and one specific AI service via a unique server that a company manages as an execution list in Proxy Security on firewall policies; employees can then only use one specific AI service because access to other AI services without a permitted network in the company is not possible. Furthermore, IT workers must build an environment in which data leakage to third parties using AI is prohibited. Overall, the application of AI with Amazon Bedrock is a secure platform. AWS claims that Amazon Bedrock is a safe AI solution since the platform separates corporate data and protects the data from model suppliers. External foundation models are never trained using business data or outputs.

Amazon Bedrock additionally provides strong encryption, fine-grained access controls, and built-in safety filters to prevent malicious material or begin attacks [9]. The isolation means that businesses may monitor users without worrying about data leaks outside of Amazon Bedrock.

3 IDENTITY-BASED AUTHORIZATION

Identity and access management is a foundational corporate technology since the platform allows users to log in to personal accounts using Single Sign-On (SSO) because IT experts have registered device and software IDs (CrowdStrike, AWS, and Azure) with the identity and access management platform. Furthermore, identity and access management reduces the workload of IT experts. Microsoft Entra ID (Azure AD) is one of the best-known technologies. Microsoft Entra ID improves enterprise authentication by delivering granular Zero Trust access control that determines who can access what, when, and how, as well as minimizing breach and compliance risk with phishing-resistant, passwordless authentication. The capabilities improve regulatory compliance and save operational costs, making Entra ID an excellent foundation for identity-based AI authorization [10] [11]. Security engineers may use AI to handle access control and compliance on Microsoft Entra ID.

One of the most critical aspects of preserving an organization's security is identity protection, and Microsoft Entra ID enables security specialists to manage users in a secure environment. The ID Protection component uses machine-learning algorithms on authentication signals to perform adaptive, risk-based assessment, which includes identifying anomalous sign-ins, allocating risk levels, and initiating automated remediation for both human users and AI agents, such as step-up authentication or access blocking [12]. The adaptive method uses a number of complementary mechanisms. Entra ID assesses sign-in activity during authentication, including connections from untrustworthy sources and odd sign-in characteristics. The platform may deny the session or require Multi-Factor Authentication (MFA) before granting access [12]. Entra ID also collects risky sign-ins over time, allowing the restriction of accounts that appear to have been hacked or forcing afflicted users to change passwords [12]. The approach fits AI governance since the reaction is based on an account's behavior rather than a predefined rule that attackers may foresee.

The second strategy involves the use of strong authentication procedures. When a user attempts to access sensitive data or generative AI systems, Entra ID may request phishing-resistant credentials, such as Windows Hello for Business or FIDO2 security keys [13]. By treating AI agents and agentic identities as principals who must fulfill access criteria rather than unmonitored automated processes, Entra ID may apply the same zero-trust conditional access engine to AI agents [14]. The approach is necessary because an ungoverned agent is just as dangerous as an ungoverned employee, and AI agents have the same rights as human users.

The third approach is automatic remediation. When anomalous behavior is observed, Entra ID can automatically request that the user execute a multi-factor

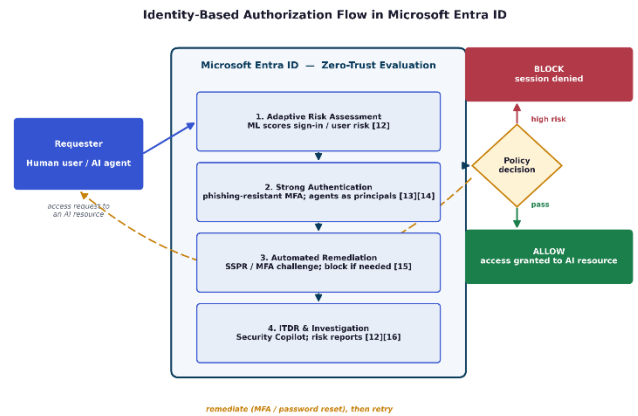


Fig.1. Identity-based authorization flow in Microsoft Entra ID

authentication (MFA) challenge or a self-service password reset (SSPR) to reduce the risk without needing human intervention [15]. A user who is assessed to be at risk in general may need to change a password before regaining access, but if just the sign-in appears dangerous, the user is normally asked to perform MFA [15]. In more risky scenarios, an administrator might put up a policy that fully prevents sign-in, requiring the user to contact IT people or try again from a reliable device or location rather than self-correct [15]. Automated remediation is necessary because routine reactions may occur without using valuable analyst time, freeing up manual participation for circumstances that require immediate attention.

The fourth method, known as Identity Threat Detection and Response (ITDR), integrates AI into security operations. By integrating Security Copilot, analysts may search for risky sign-ins using natural-language queries rather than laborious log analysis [16]. Furthermore, Entra ID Protection organizes findings into several reports, which are risk detections, dangerous sign-ins, risky users, and problematic workload identities, so that security teams can rapidly review each report, confirm genuine compromises, or rule out false positives [12]. The reporting component is connected to the previously mentioned false-positive issue: the identification layer helps analysts distinguish between serious threats and legitimate AI-driven activity by prioritizing and categorizing alerts.

When coupled, the four solutions, which include strong authentication enforcement, automated remediation, adaptive risk assessment, and AI-assisted threat investigation, enable a security team to regulate AI use at the identity level rather than the network. Because access follows the user or agent rather than a device or location, the identity layer fills in the gaps left by network-based blocking while applying the same zero-trust principles to both human users and AI agents. By doing so, Microsoft Entra ID transforms the organizational policy established in the previous tier into automatic, enforced access alternatives.

4 PROMPT-LEVEL DEFENSES

Amazon Bedrock is a controllable platform that enables enterprises to adopt AI for IT administrators. Amazon

Bedrock is a fully managed AWS service that enables developers to build AI-powered applications utilizing foundation models without the need to manage infrastructure or train models themselves [17], and administrators can select which AI model to utilize throughout the organization. Administrators, for example, can choose from 102 models such as Claude, Nova, ChatGPT, and others [18], allowing users to utilize a variety of AI; but how can a security team supervise users to use AI safely? Users might use AI for malevolent intentions, such as hacking into internal systems using prompt engineering or asking AI for sexual information and causing harm to others. When addressing AI security, a corporation must control the prompt for AI. There are two approaches to managing prompts: Amazon Bedrock Guardrails and Amazon Bedrock Flows.

4.1 Amazon Bedrock Guardrails

Amazon Bedrock Guardrails provides configurable protection for identifying and filtering problematic content in both user inputs and model responses across foundation models [19]. Instead of relying on each model's inherent safety behavior, an organization may define a single, consistent set of controls that apply regardless of whatever model a user selects. The mechanism directory addresses the aforementioned prompt-level problems by examining what users provide the model and what the model returns before either one arrives at a destination.

Amazon Guardrail consists of one or more policies that administrators tailor to a certain use case [20]. Content filters limit hazardous text or image content to specified categories such as hate, insults, sexual content, violence, misconduct, and prompt attacks, and the intensity of each category may be modified independently [19]. Denied subjects eliminate concerns that are inappropriate for the application, such as a bank rejecting requests for illegal financial advice, whereas word filters prohibit custom terms such as profanity or competitor names [19]. Sensitive information filters utilize precise regular-expression patterns to block or hide personally identifiable information (PII), such as social security numbers, dates of birth, and addresses [19]. Two additional filters prioritize reliability over abuse: contextual grounding checks flag responses that are factually ungrounded or irrelevant in retrieval-augmented generation applications, and automated reasoning checks validate responses against logical rules to detect hallucinations and unstated assumptions [19].

Enforcement operates in both directions [20]. During a model inference call, the user input is processed simultaneously against each set policy; if the analysis results in a guardrail intervention, a pre-configured blocked message is provided, and the model inference is totally refused, ensuring that the prompt never reaches the model. If the input is valid, the model's answer is checked against the same policies and either returned unmodified or, if a violation occurs, replaced with a blocked message or masked.

Because guardrails may function independently of a model via the ApplyGuardrail API and link to Amazon Bedrock Agents and Knowledge Bases, the same constraints apply consistently across an organization's AI workloads [19][20]. For a security team, the strategy centralizes

prompt-level protection at the platform rather than de-

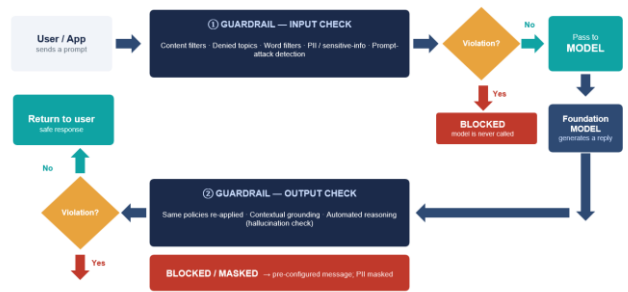


Fig.2. Amazon Bedrock Guardrails' Processing Flow

pending on individual users or each model's own security procedures.

4.2 Amazon Bedrock Flows

While Guardrails screens individual inputs and responses, many business AI applications are composed of multi-step processes rather than single exchanges. Administrators may design multi-step workflows using Amazon Bedrock Flows by joining nodes that each execute a specific activity, such as activating a model, querying a knowledge store, or running custom logic [21]. From a security standpoint, Flows are beneficial not as a filter, but because constraints may be added at each stage of a process rather than simply at the outset.

Capacity is possible due to two factors. First, guardrails can be added directly to individual nodes: both the prompt node and the knowledge base node accept guardrail configurations, allowing the same content, topic, word, and sensitive information filters described above to be applied at every point where the workflow encounters a model [22]. Second, condition nodes direct data down various branches based on relational and logical expressions, allowing an administrator to set rules that allow, redirect, or halt a process based on intermediate results [22]. When the capabilities are integrated, an organization may consistently execute a prompt-level policy throughout a big AI program, bridging gaps that a single input filter might overlook.

Guardrails and Flows offer administrators a platform-level approach to regulating how AI is used, rather than depending on individual models or individuals. Guardrails add consistent content, subject, and privacy controls to each prompt and response, whereas Flows extend the same limits across many processes. The prompt-level layer complements the prior section's identity controls: Entra ID regulates who has access to an AI service, whereas Bedrock controls what a user can do once inside, barring malicious prompts and hazardous responses before harm occurs.

5 DISCUSSION/LIMITATION

The three-layer model presented in the present paper, which is organizational policy, identity-based authorization, and prompt-level defense, is meant as a defense-in-depth strategy, with each tier compensating for the weaknesses of the previous ones. Policy defines permitted AI usage,

Microsoft Entra ID determines whose identities can access an AI service, and Amazon Bedrock restricts what the authorized identities can do once access is granted. No single layer is sufficient alone, and the basic premise of the present study is that the combination allows a security team to regulate corporate AI use without prohibiting the use entirely. However, some limits temper the conclusion and need more explanation.

First, while the identity and network limitations described here address permissible access paths, the controls do not totally rule out shadow AI. An employee can still use an unauthorized AI service from a personal device, a mobile network, or a home connection that never leaves the corporate premises. Firewall and proxy-based filtering, in particular, limit access based on network location and may be bypassed with personal hardware, virtual private networks, or tethering. The controls raise the effort required to avoid policy rather than making evasion impossible, and the limitations function best when combined with the identification layer, which tracks the person rather than the device.

Second, Amazon Bedrock's prompt-level controls only protect the AI services that a firm sends across the platform. Guardrails and Flows cannot check prompts sent to external consumer AI products, and the effectiveness of the safeguards is determined by how well an administrator configures the necessary filters, topics, and thresholds. Content filtering and prompt-attack detection are probabilistic methods: the filtering methods reduce the likelihood of damaging inputs and outputs while not ensuring that every malicious prompt or adversarial evasion attempt is recognized. A motivated insider may still design inputs that elude detection, and overly strict filtering risks inhibiting legal activity, resulting in a trade-off between security and usability that each firm must handle on an individual basis.

Finally, the current research emphasizes defensive controls, including Microsoft Entra ID and Amazon Bedrock as examples. Organizations that rely on other identity providers or cloud platforms would need to adapt the specified approaches to equivalent tools, and given the rapid development of AI security features, the specific capabilities indicated here might evolve.

6 CONCLUSIONS

The rapid use of AI in the workplace has outpaced the security measures of the companies that rely on AI, leaving IT and security teams to monitor tools that any employee may now use to generate code, query sensitive data, and investigate internal systems. The current analysis contends that no single control can bridge the gap and that good governance requires defense in depth. To conclude, the research recommended a three-layer architecture in which organizational policy, identity-based authorization, and prompt-level protection address distinct parts of the problem.

The first layer establishes approved AI usage by basing local norms on well-known frameworks such as the NIST AI Risk Management Framework and OECD principles, while

customizing the norms to a global firm's legal and cultural circumstances. The second layer, implemented through Microsoft Entra ID, limits which identities, whether human or agentic, can access an AI service by using adaptive risk assessment, strong authentication, automated remediation, and AI-assisted investigation to control access at the identity level rather than the network. The third layer, built using Amazon Bedrock Guardrails and Flows, restricts what the authorized identities may do if granted access, screening dangerous prompts and hazardous responses uniformly across all approved models and workflows.

When combined, the three levels transform a declared policy into enforceable technical controls: policy establishes the rules, identity determines who may act, and prompt-level defense restricts what a user may do. A tiered approach allows a security team to effectively manage corporate AI use, reducing the risks of unauthorized access, data leakage, and bad content, without resorting to an outright ban, which would jeopardize the productivity that makes AI technologies desirable in the first place.

REFERENCES

- [1] Osmani, A. (2024, December 4). *The 70% problem: Hard truths about AI-assisted coding*. Elevate. <https://addyo.substack.com/p/the-70-problem-hard-truths-about>.
- [2] Malter, N. (n.d.). *Futurium / Apply AI Alliance - Writing an Organizational AI Policy: First Step towards Effective AI Governance*. <https://futurium.ec.europa.eu/en/european-ai-alliance/community-content/writing-organizational-ai-policy-first-step-towards-effective-ai-governance>.
- [3] *AI RMF - AIRC*. (n.d.). NIST AI Resource Center. <https://airc.nist.gov/airmf-resources/airmf/>.
- [4] *App. C: AI Risk Management and Human-AI Interaction - AIRC*. (n.d.). NIST AI Resource Center. <https://airc.nist.gov/airmf-resources/airmf/appendices/app-c-ai-risk-management-and-human-ai-interaction/>.
- [5] *AI principles*. (n.d.). OECD. <https://www.oecd.org/en/topics/sub-issues/ai-principles.html#:~:text=The%20OECD%20AI%20Principles%20promote,stand%20the%20test%20of%20time>.
- [6] Hofstede, G., Hofstede, G. J., & Minkov, M. (2010, May 3). *Cultures and Organizations: Software of the Mind*, 3rd ed, McGraw-Hill.
- [7] E. B. Bergiel, B. J. Bergiel, and J. W. Upson. (2012, January 1), "Revisiting Hofstede's dimensions: Examining the cultural convergence of the United States and Japan," *American Journal of Management*, vol. 12, no. 1, pp. 69–79.
- [8] Sartor, G., Lagioia, F., *Panel for the Future of Science and Technology, European Parliamentary Research Service, & Scientific Foresight Unit (STOA)*. (2020). The impact of the General Data Protection Regulation (GDPR) on artificial intelligence. In STOA (p. PE 641.530) [Report]. [https://www.europarl.europa.eu/Reg-DATA/etudes/STUD/2020/641530/EPRS_STU\(2020\)641530_EN.pdf](https://www.europarl.europa.eu/Reg-DATA/etudes/STUD/2020/641530/EPRS_STU(2020)641530_EN.pdf).
- [9] *Security compliance*. (n.d.). Amazon Web Services, Inc. <https://aws.amazon.com/bedrock/security-compliance/>.
- [10] *Microsoft Entra ID (Formerly Azure AD) / Microsoft Security*. (n.d.). <https://www.microsoft.com/en-us/security/business/identity-access/microsoft-entra-id?msocid=2e66e493bf5f66550e76f3a7bef36758>.
- [11] Justinha. (n.d.). *Microsoft Entra authentication overview - Microsoft Entra ID*. Microsoft Learn. <https://learn.microsoft.com/en-us/entra/identity/authentication/overview-authentication>.

- [12] Shlipsey. (n.d.). *What is Microsoft Entra ID Protection? - Microsoft Entra ID Protection*. Microsoft Learn. <https://learn.microsoft.com/en-us/entra/id-protection/overview-identity-protection>.
- [13] Shlipsey. (n.d.-a). *Risk detection types and levels - Microsoft Entra ID Protection*. Microsoft Learn. <https://learn.microsoft.com/en-us/entra/id-protection/concept-risk-detection-types>.
- [14] Ricketts, J. (n.d.). *Secure Generative AI with Microsoft Entra - Microsoft Entra*. Microsoft Learn. <https://learn.microsoft.com/en-us/entra/architecture/secure-generative-ai>.
- [15] Shlipsey. (n.d.-b). *User self-remediation with Microsoft Entra ID Protection - Microsoft Entra ID Protection*. Microsoft Learn. <https://learn.microsoft.com/en-us/entra/id-protection/concept-identity-protection-user-experience>.
- [16] Werner, C. (n.d.). *Security Copilot in Microsoft Entra*. Microsoft Learn. <https://learn.microsoft.com/en-us/entra/security-copilot/security-copilot-in-entra>.
- [17] *Amazon Bedrock – Build genAI applications and agents at production scale – AWS*. (n.d.). Amazon Web Services, Inc. <https://aws.amazon.com/bedrock/>.
- [18] *AWS Bedrock* (n.d.). Amazon Web Services, Inc. <https://modelavailability.com/platforms/aws>.
- [19] *Detect and filter harmful content by using Amazon Bedrock Guardrails - Amazon Bedrock*. (n.d.). Amazon Web Services, Inc. <https://docs.aws.amazon.com/bedrock/latest/userguide/guardrails.html>.
- [20] *How Amazon Bedrock Guardrails works - Amazon Bedrock*. (n.d.). Amazon Web Services, Inc. <https://docs.aws.amazon.com/bedrock/latest/userguide/guardrails-how.html>.
- [21] *Key definitions for Amazon Bedrock Flows - Amazon Bedrock*. (n.d.). Amazon Web Services, Inc. <https://docs.aws.amazon.com/bedrock/latest/userguide/key-definitions-flow.html>.
- [22] *Node types for your flow - Amazon Bedrock*. (n.d.). Amazon Web Services, Inc. <https://docs.aws.amazon.com/bedrock/latest/userguide/flows-nodes.html>.